

TLS Vulnerability Check

Import

The **Transport Layer Security - TLS1** protocol is perhaps the most classic network security protocol, establishing secure connections between a client and a server, with the following security services:

- 1) **Confidentiality** of the information transmitted, through symmetric encryption
- 2) **Integrity** of the information transmitted, through authentication techniques (which is why we ultimately refer to "authenticated encryption")
- 3) **Authenticate** the server (and, optionally, the client) via digital certificates (you can recall Task 1). The public key listed in the server's digital certificate is used to securely exchange the keys required for authenticated encryption.

On the Internet, for secure access to **http** websites, the TLS protocol is implemented at the underlying network layer, which is how we ultimately have the **https protocol**.

The most recent version of the protocol is **TLS 1.32**. However, older versions still exist – some of which, if implemented with incorrect settings, can cause security issues. Examples of such versions include:

- § Many versions of the protocol, including the previous one
TLS 1.23, support, among others, weak cryptographic algorithms (cipher suites) – e.g. the symmetric RC4 algorithm (which is not considered secure), the asymmetric Diffie-Hellman algorithm and/or RSA without secure key sizes, etc.
- § Many versions, especially from **TLS 1.14** and earlier (called SSL 1, SSL 2, SSL 3) have inherent design weaknesses (e.g. padding bits in cryptographic algorithms are not included in the data being authenticated, which can lead to effective attacks such as the **POODLE5 attack**).

¹ <https://hpbnc.co/transport-layer-security-tls/>

² <https://datatracker.ietf.org/doc/html/rfc8446>

³ <https://datatracker.ietf.org/doc/html/rfc5246>

⁴ <https://datatracker.ietf.org/doc/html/rfc4346>

⁵ <https://www.techtarget.com/whatis/definition/POODLE-attack>

§ Even if a server supports the most recent version of the protocol, issues arise if it simultaneously supports – for the sake, e.g., of serving users using old browsers – older versions. A typical case is the **DROWN6 attack**, which allows the recovery of encrypted information that has been exchanged with a secure version of the protocol, simply because the server simultaneously supports older insecure versions (and has the same certificate as them).

TLS vulnerability scanning tools

There are tools available that scan websites for TLS implementations, identifying vulnerabilities. Many tools run via a desktop installation (<https://linuxsecurity.expert/security-tools/ssltls-scanners>), while others are available as web tools in their own right (see, e.g., B.C,

tools and do not require any installation (e.g. <https://www.ssllabs.com/ssltest/>, <https://hackertarget.com/ssl-check/> - the second website also provides a brief description of known vulnerabilities in TLS implementations, which these tools examine, and which will help you explain the results you will receive).

Laboratory environment

This exercise can **also be performed outside** the **SEEDUbuntu** virtual machine - Ubuntu **16.04**, using any **Linux installation**. To perform the exercise, you only need to install the **ssltls-scanners** tools and use a **web browser**.

⁶ <https://drownattack.com>

Activity 1: TLS Scanning in online stores

The goal of this activity is to check e-shop applications for vulnerabilities related to the TLS protocol. Using **two different TLS**

scanning tools (of any type, of your choice), check a website **of your choice** that concerns an e-shop. List the reports from both tools, see if the tools “agree” in their findings (commenting on whether one

performs, e.g., more extensive checks), and comment in your own words on the overall security of the website. For vulnerabilities that may be found, you will need to look up information as to what exactly they concern – in which case, you should cite your sources.

In your report, in addition to describing your choices (tools, online store), you should cite the reports from both tools, see if the tools “agree” in their findings (commenting on whether one performs, e.g., more extensive checks), and comment in your own words on the overall security of the website. For vulnerabilities that may be found, you will need to look up information on what exactly they concern – in which case, you should cite your sources.

Activity 2: TLS Scanning on news sites

Similar to Activity 1, but this time you will check a **news site** of your choice.

Activity 3: TLS Scanning on University sites

Similarly to Activity 1, but this time you will check a **University** website of your choice.

Activity 4: TLS Scanning of a suspicious website

Some users in your organization, where you work as a **Security Manager**

Networks, have informed you that it appears that their personal data has been leaked to

same period of time. Studying their online movements, it emerged that all of them because users had visited the website <https://www.blackboxresale.com/login.aspx>.

Please comment on whether you think it is likely that the leak originated from this website. Develop a rationale based on your findings from a TLS **vulnerability scan** . of this specific website.

Submission

You must submit a detailed **lab report** (in PDF) covering all the actions you took in each activity, your results and your observations. In your description, use the references from the tools, according to the instructions for each activity.